

Non-Executing Security Analysis of AI Model Supply-Chain Artifacts

Provenance, Serialization, Impersonation, and Repository Risk Inspection

github.com/poojakira/hf-model-provenance-scanner - public, default branch main.

EVIDENCE POSTURE

Verified, scoped, reproducible

Claims are constrained to the repository evidence snapshot and stated limitations.

241

Tests passed

1

Tests skipped

6

Additional pytest subtests passed

75.67%

Statement coverage

SYSTEM VIEW

Architecture and Threat-Control Flow



Research Contribution

A primarily non-executing model-artifact security scanner combining static code analysis, symbolic and taint-style inspection, binary-format parsing, provenance checks, and fail-loud handling of incomplete analysis before model loading.

Verified Evidence

EV-01 CI coverage gate: 75%

Method and Control Path

- 01

Enumerate repository and model artifacts.
- 02

Parse supported serialization/model formats.
- 03

Apply AST, pattern, symbolic, taint-style, metadata, and provenance checks.
- 04

Reject unsafe dynamic-execution paths in the scanner itself.
- 05

Emit findings and fail-loud states for incomplete or unsafe analysis.

Limitations and Residual Risk

- Static analysis cannot prove a model is safe.
- No claim is made that neural weight backdoors are generally detected.
- Fixture-level results do not establish population-level precision or recall.
- Unsupported or incomplete parsing must remain fail-loud rather than silently clean.

Reproducibility

Expected evidence at the cited snapshot: 241 passed, 1 skipped, 6 subtests passed, 75.81% coverage.

Evidence Provenance

- Claim discipline**
Metrics come from the repository's verified metrics and research brief.
- Scope discipline**
Benchmarks are reported only at their documented fixture, dataset, or test scope.
- Reproduction**
PDF and PNG are generated locally from committed evidence without paid services.